

ISO 27001 Implementation Checklist

A practical checklist for building an ISO 27001 information security management system (ISMS).

1. Context & scope

- ☐ Define the boundaries and scope of the ISMS
- ☐ Identify internal/external issues relevant to information security
- ☐ Identify interested parties and their requirements

2. Leadership & policy

- ☐ Secure top-management commitment and resources
- ☐ Establish an information security policy
- ☐ Assign roles, responsibilities and authorities

3. Risk assessment & treatment

- ☐ Define the risk assessment methodology
- ☐ Identify information security risks and owners
- ☐ Evaluate and prioritise risks
- ☐ Select risk treatment options and controls

4. Statement of Applicability (SoA)

- ☐ Document applicable Annex A controls
- ☐ Justify inclusions and exclusions
- ☐ Record implementation status of each control

5. Controls (Annex A themes)

- ☐ Organisational controls (policies, roles, supplier security)
- ☐ People controls (screening, awareness, responsibilities)
- ☐ Physical controls (access, equipment, media)
- ☐ Technological controls (access, cryptography, logging, backup)

6. Operation, monitoring & improvement

- ☐ Implement controls and keep records of operation
- ☐ Set objectives and measure performance
- ☐ Run internal audits across the ISMS
- ☐ Hold management reviews
- ☐ Manage nonconformities and corrective actions